

[doc. web n. 10090499]
Provision of November 13, 2024
Register of provisions
n. 674 of November 13, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC-General Data Protection Regulation (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data"
(hereinafter "Code");

HAVING REGARD TO the Ethical Rules for processing for statistical or
scientific research purposes carried out
within the National Statistical System
published and adopted by the Guarantor pursuant to Article
20, paragraph 4, of Legislative Decree No. 101 of August 10, 2018, with
provision No. 514 of December 19, 2018, attached A4
to the Code (doc. web 9069677, hereinafter "Ethical Rules");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary
General pursuant to Article 15 of the Guarantor's Regulation No. 1/2000 on the
organization and functioning of the office of the Guarantor for the
protection of personal data, at www.gpdp.it, doc.
web n. 1098801;

Reporting Attorney Guido Scorza;

WHEREAS

1. The inspection activity

The Office of the Guarantor on the days of XX and XX has

conducted inspection checks at the National Institute of Social Security (hereinafter "Inps"
or "Institute") in order to "verify the compliance by
the Statistics Office with the provisions
regarding the protection of personal data in
processings carried out for official statistical purposes
with particular reference to the correct
application of the principles of personal data
protection and the measures referred to in Article 89 of
the Regulation" (service order No. XX of XX).

In the context of this inspection activity, the Office of the
Guarantor focused on verifying the actual
application of the principles of transparency,

data minimization, storage limitation, accountability, privacy by design and by default, as well as the obligation to carry out the impact assessment (Articles 5, paragraph 1, letters c), e), paragraph 2, Articles 13, 14, 25, 35 of the Regulation), also with reference to two specific statistical works:

- 1) "IPS-00081 – Pension benefits and beneficiaries of the Italian social security system;
- 2) "IPS-00061 – Longitudinal sample of insured persons and pensioners".

On the day of XX, it was highlighted by the holder that one of the main activities of the statistical coordination office consists in the creation of statistical observatories - to which corresponds a sheet of the National Statistical Program (PSN) - intended for publication on the official Inps website as an output of specific statistical works.

The construction of the statistical bases necessary for the realization of the observatories is the responsibility of the actuaries assigned to the office who access the data necessary for this purpose, present in the administrative sources of the Institute, made available in a specific environment, "data warehouse" (DWH), which contains tables of microdata (i.e., data referring to individual data subjects).

For the realization of the observatory, the actuary imports from the DWH into their system the tables of interest and performs at a glance a verification of the accuracy, correctness, and consistency of the imported data. Once this operation is completed, the actuary proceeds to construct the statistical data base that contains aggregated data. Subsequently, the aggregated statistical data base is passed to the IT structure that publishes it in the observatory using a k-anonymity technique, which consists of applying the so-called rule of 3 (in other words, every set subject to statistical survey, as declared, always has a number greater than three units, regardless of the combination of attributes used to characterize it).

The actuary, depending on the relevant coordination, receives "one-time" authorization to request access to the corresponding partition of the DWH. Subsequently, every request for data updates is made via email.

Access to the DWH (to the relevant tables) by statisticians is read-only.

The Institute has stated that it has formalized the authorization procedure for the import/update of the tables of its interest for the establishment of the aggregated statistical data base in a manual of which a copy has been provided. It has also been stated that all actuaries

of Inps obtain authorization for access and processing of data based on the role/task/ assignment to which they are assigned and for the entire duration of the same.

It was, therefore, illustrated by way of example the statistical work "IPS 00081 – Pension benefits and beneficiaries of the Italian social security system" (hereinafter also

IPS-00081), contained in the PSN and aimed at providing the statistical framework of existing pensions year by year for which, accessing the DWH, the actuary extracts the variables of interest. In this regard, the Institute has stated that it cannot exclude that, by accessing the data contained in the DWH, necessary for the realization of a statistical work (e.g., IPS 00081), the statistician may in theory view data referring to periods different from those of interest and that the actuary accesses identifying data, containing the tax code of the statistical units. The data, therefore, are not subject to any pseudonymization measures. The actuary extracts from the DWH only the variables necessary for the realization of the statistical work of interest, importing them into a specific environment (SAS server) where such information is stored for a period of 5 years, for the realization of historical series, and for an additional 10 years, for a total of 15 years, at a backup server of the Institute. In the information sheet of the statistical work IPS-00081 of the PSN, last present in the National Statistical Program 2023-2025, the data retention period is indicated as 120 months. The Institute has also stated that an impact assessment is currently being processed for this work pursuant to Article 35 of the Regulation, for which the version in its elaborated state has been acquired. The organization mode of the statisticians' work, which involves the importation of data of the interested parties including the tax code, has been in use for about twenty years, that is, since the DWH was introduced within the Institute. The Institute has reported that the current organization is necessary as it would be the only one capable of meeting the needs of official statistics characterized by both urgency and ordinariness. However, it has been confirmed that for the realization of statistical works, such as the "observers," the statistician may not need directly identifying data of the statistical units, such as the tax code, and that therefore the DWH could be subject to modifications to extract pseudonymized data, while still maintaining a unique code for each individual interested party recorded in the Institute's databases. On November 28, the Institute presented the work "IPS 00061 – Longitudinal sample of insured and pensioners" (hereinafter also IPS-00061) as an example of longitudinal work. Initially, it was represented that currently actuaries can acquire updates of the tables from the DWH only upon request, via the Inps portal, which concerns allegedly "anonymized" data. However, it was clarified that the actuary does not know how the anonymization of the data is carried out and that the request is necessary to provide the data to the "Studies and Research" Directorate, which cannot access clear data. The process of "anonymization" is carried out by the DWH technicians directly at the "SQL" language level and consists solely of the encryption of immediately identifying data (such as, for example, the tax code), using an encryption algorithm. This function is not used for the aggregation of statistical data on the Inps portal but only for the production of data that is provided to the "Studies and Research" Directorate. The described requirements for "anonymization" of the data are the only ones currently provided, and the research analyses that make use of such data are published in the annual report or on the institutional website of the Institute. The Institute has also stated that the aforementioned measures for encrypting directly identifying data, even for the provision of data to the statistical coordination, could in theory be implemented, but currently, the DWH staff limit themselves to verifying that the subjects requesting data and tables are authorized, providing them in the requested form (currently microdata directly identifying the statistical units). With reference to the dissemination of statistical results on its institutional website, it was represented that this is carried out taking into account the so-called 3-rule, based on a procedure that the statistical coordination indicates to an external company to avoid the publication of "hypercubes" (i.e., compositions of intervals of the different variables in which the data can be represented) containing a number of statistical units less than 3. The aforementioned company returns the table to the statistical coordination which, before the publication of the statistical results, performs an additional check on the received data *ictu oculi* and by

sampling, while the external company carries out the above-described operation in an automated manner. On this point, it was subsequently clarified that "The General Statistical Actuarial Coordination has not currently found the documentation regarding the rules that the Institute has imparted to the external company to avoid the publication of the so-called 'hypercubes' containing a number of statistical units less than 3 units." The Institute has represented that the staff has received specific training in the field of personal data protection, providing the relevant evidence. In relation to the statistical work IPS-00061, it was clarified that it was included in the PSN until version 20 – 22, update 2021, and that, being a closed project study that did not produce any output, the data collected in the SAS environment have been deleted and never uploaded to the Institute's backup systems.

2. The regulations on personal data protection

The processing of personal data must take place in compliance with the Regulation and the Code, as well as, with

specific reference to the sector in which one operates, of the Ethical Rules, Annex A4 to the Code.

For "personal data," it is meant "any information relating to an identified or identifiable natural person ('data subject')." Furthermore, "a natural person is considered identifiable who can be identified, directly or indirectly, particularly by reference to an identifier such as a name, an identification number, [...]" (Article 4, paragraph 1, point 1 of the Regulation).

Pseudonymization is defined as: "the processing of personal data in such a way that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and subject to technical and organizational measures intended to ensure that the personal data cannot be attributed to an identified or identifiable natural person" (Recital 26 and Article 4 point 5).

Pseudonymized data are therefore personal data that have undergone prior coding treatment.

Specifically, pseudonymization is not a method of anonymization; it merely reduces the correlation of a set of data to the original identity of a data subject and thus represents a security measure that the data controller is required to implement, also in order to effectively apply data protection principles, where it is no longer necessary to have identifiable personal data, by separately storing the identification keys (cf. Opinion 05/2014 on anonymization techniques adopted by the Article 29 Working Party on April 10, 2014, and the Guidelines 4/2019 on Article 25 Data Protection by Design and by Default, Version 2.0, adopted by the European Data Protection Board on October 20, 2020).

Based on the principle of minimization, data must be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed (Article 5, paragraph 1, letter c) of the Regulation). Pseudonymization constitutes a measure of utmost importance in the field of statistical research, particularly to ensure effective application of the principle of minimization (Articles 5, paragraph 1, letter c) and 89 of the Regulation). In this regard, the Article 29 Working Party has highlighted that it serves "to reduce the correlation of a set of data to the original identity of a data subject, and therefore represents a useful security measure (WP216, 05/2014 on anonymization techniques adopted on April 10, 2014)" but certainly also constitutes a data minimization measure that realizes and operationalizes the principle of necessity. Among the main elements of design and default settings related to data minimization, pseudonymization of data is indeed included (cf. paragraph 3.5. Guidelines 4/2019 of the European Data Protection Board, cited).

Personal data must be processed in compliance with the principle of transparency as per Article 5, paragraph 1, letter a) of the Regulation, which correlates with the obligation to provide data subjects with information about the processing in advance, in cases of data collected from third parties, according to the methods set out in Article 14 of the Regulation. In this regard, Article 6, paragraph 2 of the Ethical Rules establishes that "When the processing concerns personal data not collected from the data subject and providing the information to the latter requires a disproportionate effort in relation to the protected right, according to what is provided for by Article 14, paragraph 5, letter b) of the Regulation, the information is considered provided if the processing is included in the national statistical program or is subject to publicity in suitable ways."

The principle of data retention limitation is also relevant, as per Article 5, paragraph 1, letter e) of the Regulation, according to which data are "kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the data are processed; personal data may be stored for longer periods provided that they are processed solely for archiving purposes in the public interest, for scientific or historical research, or for statistical purposes, in accordance with Article 89, paragraph 1, subject to the implementation of appropriate technical and organizational measures required by this Regulation to safeguard the rights and freedoms of the data subject."

Among the principles applicable to processing, the principle of accountability establishes that "the data controller must comply and be able to demonstrate both compliance with the principles and obligations set out in the Regulation" (Article 5, paragraph 2 of the Regulation).

This is linked to another duty placed on the data controller, namely to ensure that the rights and regulations regarding the personal data protection of data subjects are safeguarded and applied from the design stage and by default (so-called privacy by design and by default, Article 25 of the Regulation).

Therefore, a careful evaluation of all choices related to personal data processing is required, demonstrable logically through specific justifications aimed at identifying necessary and proportionate measures concerning the concrete effectiveness of the principle being safeguarded at any given time.

In compliance with the obligation of data protection by design, data controllers must also take an active approach in applying the principles, aiming to achieve a real protective effect. Therefore, mere compliance is not required.

application of generic measures, not directly related to the purpose of protection, but of qualitatively and quantitatively effective measures with respect to the objective and designed to be, when necessary, revised in relation to any increases or decreases in risks for the data subjects. Such measures should, where possible, include specific indicators aimed at unequivocally demonstrating their effectiveness. In this perspective, the aforementioned obligation to document the choices related to the processing of personal data is considered fully fulfilled only where the data controller is able to demonstrate, through performance indicators (qualitative and, where possible, quantitative), the effectiveness of the measures adopted or intended to be adopted (cf. Guidelines 4 of 2019 cited, provision of the Guarantor of January 23, 2020, web doc no. 9261093).

The Regulation also provides that "when a type of processing, particularly when it involves the use of new technologies, considering the nature, purpose, context, and objectives of the processing, may present a high risk to the rights and freedoms of natural persons, the data controller shall carry out, prior to processing, an assessment of the impact of the intended processing on the protection of personal data. A single assessment may examine a set of similar processing operations that present similar high risks" (art. 35; Article 29 Working Party Guidelines no. 248 concerning "The impact assessment on the protection of personal data and the criteria for determining whether processing" adopted in amended form on October 4, 2017).

In particular, the European Data Protection Board has deemed it necessary to conduct an impact assessment (DPIA) whenever the processing may present a high risk to the rights and freedoms of natural persons, particularly those that involve: i) the evaluation or assignment of a score; ii) automated decision-making that has legal effects or similarly significantly affects the data subject; iii) systematic monitoring; iv) processing of sensitive data or data of a highly personal nature; v) processing of data on a large scale; vi) the creation of correspondence or combination of data sets; vii) processing of data relating to vulnerable data subjects; viii) innovative use or application of new technological or organizational solutions; ix) processing that prevents data subjects from exercising a right or using a service or a contract. In particular, the European Data Protection Board believes that a DPIA must certainly be carried out whenever at least two of the aforementioned criteria are simultaneously present (Guidelines of October 4, 2017, cited).

The regulation on the protection of personal data does not concern anonymized data, understood as only those that do not allow for the direct or indirect identification of a person, taking into account all

means (economic, information, technological resources, skills, time) available to those (data controller or other subject) attempting to use such means to identify a data subject. Anonymization cannot be considered achieved through the mere removal of the data subject's personal details or their replacement with a pseudonymous code. An anonymization process cannot be deemed effective if it does not prevent anyone using such data, in combination with "reasonably available" means, from being able to:

1. isolate a person in a group (single-out);
2. link an anonymized data to data referring to a person present in a distinct data set (linkability);
3. deduce new information relating to a person from an anonymized data (inference) (cf. Opinion 05/2014 - WP 216 on anonymization techniques, adopted on April 10, 2014).

3. Alleged Violations

In light of the aforementioned regulatory framework, based on the elements acquired during the referenced inspection activity as well as subsequent evaluations carried out, the Office - with act of XX, prot. no. XX, notified on the same date via certified email, which must be understood as fully reproduced here - has initiated a procedure for the adoption of measures referred to in art. 58, par. 2 of the Regulation, against the Institute, inviting it to produce defensive writings or documents and to request to be heard by the Authority (art. 166, paragraphs 5, 6, and 7, of the Code, as well as art. 18, paragraph 1, law no. 689 of November 24, 1981).

With the aforementioned act, the Office noted that the processing of personal data carried out by INPS for the pursuit of institutional functions related to the realization of official statistics has been conducted in violation of the principles of data minimization, limitation of storage, accountability, and privacy by design and by default as per art. 5, par. 1, lett. c) and e), par. 2, and art. 25 of the Regulation, as well as with specific reference to statistical work IPS-00081, the obligation to provide accurate and complete information pursuant to art. 14 of the Regulation and, in relation to statistical works included in the PSN and in particular to those verified during the inspection assessments (IPS-00081 and IPS-00061), the obligation to conduct a prior impact assessment, pursuant to art. 35 of the Regulation.

4. The Defensive Memoranda of INPS and the Authority's Evaluations

The Institute, with note of XX (prot. no. XX), has submitted its defensive memoranda, providing **Declarations for which the signatory is criminally liable under Article 168 of the Code and without requesting to be heard in a specific hearing, as provided for by Article 166, paragraph 5 of the Code, in which it has been particularly represented as follows.**

4.1. On the principles of privacy by design and by default and data minimization

With regard to the contestation of the violation of the principles of data minimization and privacy by default and by design, as per Articles 5, paragraph 1, letter c) and 25 of the Regulation, in relation to the collection by the DWH of directly identifiable data of the data subjects through the indication of the tax code of each of them, which the statistician views, imports, and collects information in this format, that is, without any prior form of pseudonymization, the Institute has represented that "In the context of the production of official statistics, the presence of the clear identifier responds [...] to the need to allow in the qualitative processing phase of the data, not only to adopt measures for massive statistical control of the correctness and robustness of the data but also to carry out targeted accesses on a limited number of cases for the verification of anomalous data through the transactions and web applications available in the Institute [...].

In the process of producing official statistics, the added value of the processing carried out [...] consists in transforming a series of administrative information, typically affected by errors, duplications, incompleteness, and various anomalies, into reliable, complete, and robust statistical information capable of effectively representing the phenomena analyzed from time to time concerning multiple thematic areas of great interest to the Country. [...]

"For this reason, in this specific case, considering the type of archives and the data contained therein, in order to achieve the accuracy and reliability of the statistics, the targeted intervention to improve the quality of the results, through the exchange and research of specific information on anomalous positions, is usefully achievable, in reasonable times and with reasonable efforts, by using the tax code

of the interested parties.

It is, moreover, data processing [...] carried out by professionals registered in the register and, in any case, required to comply with a code of ethics, which in Article 5 – Confidentiality – imposes on the Actuary the obligation of professional secrecy and to maintain a reserved attitude regarding the information learned in the exercise of the profession. [...]

Indeed, attention should not only be placed on the strict observance of the most restrictive interpretation of the provisions, without taking into account the real needs and situations, but also on the means, times, and efforts necessary to achieve the best result pursued, in relation to the specific interests involved, also considering the safeguarding of the right to privacy that is nonetheless ensured through compliance with the obligations and ethical and professional standards to which the actuary is bound. [...]

Moreover, not only the context of particular operationality, considering the number and types of requests to be fulfilled [...] but also the need to ensure the provision of statistical data, in significant volumes and tight timelines, should be considered as a circumstance that justifies a more immediate processing method, such as the use of the clear tax code, to optimize the massive statistical control of the correctness and robustness of the data and improve the qualitative processing, also with targeted checks on a limited number of cases, through reconciliations and web applications available in the Institute [...].

It is undeniable that due to the circumstances, conditions, and particularities of the needs for timeliness and precision, the data, even with the use of the tax code, should be considered processed in an adequate, relevant, and limited manner to what is necessary concerning the purposes for which they were processed [...].

It is not denied that the application of pseudonymization to personal data, replacing the tax code with a pseudonym as the only visible information to the actuaries of the CGSA, could reduce risks for the data subjects and help the data controllers comply with their data protection obligations, always leaving them the possibility to trace back to the identity of the data subject where necessary.

However, the replacement of the tax code with a pseudonym, likely not applicable to all statistical processing, would not allow maintaining the current standard of timeliness and accuracy of statistical activities, risking to jeopardize the effectiveness and efficiency of the activities carried out by the CGSA [...].

Finally, it should be considered that the tables present in the DWH are several hundred, therefore, the potential process of replacing the tax code with the pseudonym would require an unspecified time to be made operational by the DCTII with inevitable repercussions on the activities of the CGSA.”

In conclusion, the Institute believes it cannot share the Authority's observations where it has been noted that the databases in “non-anonymous” form do not comply with the principles regarding the protection of personal data, particularly with reference to those of minimization, integrity, and confidentiality.

On this point, it is preliminarily noted that the pseudonymization of data constitutes a measure that, while preserving the possibility for the data controller to trace back to the identity of the data subject where necessary, simultaneously facilitates the effective...

****Application of the principles (legally binding) of personal data protection, with particular reference to those of minimization, integrity, and confidentiality. Pseudonymized data allows for the maintenance of singularity, useful as represented by the Institute to "achieve the accuracy and reliability of statistics, targeted intervention to improve the quality of results, through the exchange and research of specific information on anomalous positions, is achievable, within reasonable time and effort." They are indeed still personal data, albeit subject to a coding measure (cf. Guidelines and Opinion, cited; provision of January 23, 2020, web doc 9261093).****

****In the field of scientific and statistical research, the discretion for the data controller to apply or not apply such a technique is significantly reduced in light of Article 89, paragraph 1 of the Regulation. The centrality of pseudonymization in the context of personal data processing for statistical purposes is understood due to the very nature of research, which is concerned with examining phenomena, their incidence in specific contexts, their frequency, etc., regardless of the identity of the subjects involved.**

This is to the extent that according to the Regulation, the choice of data minimization—particularly through their pseudonymization—must take on a residual character and be subordinate to the even more protective measure of processing, where possible, anonymized data.**

From another perspective, and taking into account the observations made by INPS in its submissions, it is noted that the Authority has already highlighted how such a measure can, rather than hinder the realization of statistical activity, promote a fair balancing with the principles of data protection, with particular reference also to those of purpose limitation and retention (cf. provision of January 23, 2020, web doc no. 9261093 and provision of September 16, 2021, point 3, web doc no. 9717477).

The application of organizational measures, as required by the Regulation (Article 32), including ethical measures and the professional secrecy to which actuaries are bound, does not allow for the exclusion of the legal binding nature of all other principles of personal data protection. The obligations and principles of data protection are not, in fact, alternative to each other or capable of excluding one another, but must be applied jointly in order to ensure, on the one hand, the level of protection for the rights and fundamental freedoms of the data subjects required by the Regulation and, on the other hand, to reduce the risks inherent in personal data processing to an acceptable level.

While it is correct and undeniable that the measures necessary for the effective application of the principles of minimization and privacy by design and by default must be identified by each individual data controller in relation to their specific context, such as the volume and type of data processed, the available resources, the purpose of processing, and the state of technological art (elements that must be considered in order to increase and not reduce the robustness of the measures to be adopted), it cannot be overlooked that the Institute has not initiated any reflection on the fruitful use of this tool, even for the benefit of data quality, in the context of the processing activities necessary for the realization of official statistics.

In conclusion, the Institute has added that “while considering that the necessity should be excluded, [...], if a process for the replacement of the Tax Code with the pseudonym were to be initiated, it should still occur gradually, providing for an intermediate phase in which both pieces of information are present in the databases to ensure continuity of the internal procedures of the CGSA and avoid a halt in work that could last several months, risking making the achievement of specific objectives impossible or severely jeopardizing it.”

By way of example, it is noted that the Authority has prescribed to the National Institute of Statistics a pseudonymization system based on a hierarchical decoupling mechanism of pseudonymized codes in various databases and their rotation over time, given the volume of data subject to processing for the production of official statistics, increasingly often acquired by accessing administrative sources. The measure has been prescribed, both to minimize human errors, more likely in the presence of significant volumes of data or multiple sample extractions, and to ensure effective application of the principles of purpose limitation and retention, as well as to make possible the interconnection of multiple tables in cases where this constitutes the institutional purpose of the survey and is permitted by law (provision of January 23, 2020, cited).

It is also noted in this regard that, with the provision of September 16, 2021 (web doc 9717477), the Authority, in providing its opinion on the Psn 2020-2022, update 2021-2022, represented what measures have been implemented by Istat following the provisions adopted against Istat, taking into account the large volume of data held by that administration (provision of January 23, 2020, cited; provision of February 13, 2020, web doc 9283929; provision of May 19, 2020, no. 87, web doc no. 9370217), observing that there are “other public administrations that share similar characteristics to those of [Istat] in terms of massive collection and complex reprocessing of personal data also related to particular categories for purposes.”

"statistical" explicitly referring to Inps. The Authority has therefore noted that "These types of processing require more urgent attention, also following specific impact assessments, for the implementation of adequate technical and organizational measures to ensure the effective application

of the principle of data minimization and, in particular, the use of appropriate and advanced techniques of pseudonymization." Such considerations do not allow for overcoming the contestation in question regarding the violation, by Inps in the performance of its institutional functions in the field of official statistics, of the principles of data minimization and privacy by design and by default as per Articles 5, paragraph 1, letter c) and 25 of the Regulation.

4.2 On the principle of data retention limitation

Regarding the contestation of the violation by the Institute of the principle of data retention limitation as per Article 5, paragraph 1, letter e) of the Regulation, particularly concerning the statistical work IPS-00081, due to the holder's choice to pre-determine the data retention period to 15 years, the Institute first represented that "in the PSN sheets, the data retention period for historical series is indicated as 120 months." It clarified that "The CGSA has indicated 120 months (10 years) as the retention period for the entire five-year historical series processed in a given year; therefore, the 10 years of retention refer to the year of processing of the historical series, as they may constitute the scientific basis upon which some hypotheses for future statistical, scientific, or historical research can be founded and based on which the reliability of the research itself and the authenticity of the results can be verified." The Institute has, in any case, highlighted that "the CGSA is working on adjusting all the PSN sheets to [...] adapt the retention period to the actual informational needs." The collection of data in the Inps SAS environment constitutes a duplication within the Institute which, if necessary, should not persist beyond the time required for the purpose of the collection. This circumstance must be considered within the evaluations that the holder is required to carry out from time to time to ensure the effective application of the principle of personal data protection considered, in this case, that of data retention limitation, avoiding standardized solutions. As repeatedly emphasized by the Authority, in the field of research, retention periods should be identified based on specific technical-scientific motivations (see provision no. 498 of October 26, 2023, web doc 9960973; no. 607 of December 21, 2023, web doc 9979453; no. 36 of January 24, 2024, web doc 9988614). Nevertheless, while deeming it appropriate to recommend a more scrupulous definition of retention periods in relation to the purpose pursued through each individual statistical work carried out by the Statistics Office and the very nature of the work (Survey Statistics, Derived Statistics or Reprocessing, Project Studies, Longitudinal Studies), taking into account the commitment made, it is believed that the motivations provided can be considered adequate, from a legal-technical standpoint, to overcome the contestation in question, also considering the type (observers) of statistical projects carried out.

4.3. Information to data subjects

Regarding the violation by the Institute of the obligation to provide accurate and complete information pursuant to Article 14 of the Regulation, arising from the inconsistency between the actual retention period applied (15 years) and what is indicated in the information sheet of the PSN 2023-2025 related to the statistical work IPS 00081 (120 months/10 years), which serves as information to data subjects pursuant to Article 6, paragraph 2 of the Ethical Rules, the Institute represented that "the CGSA is working on adjusting all the PSN sheets to take this observation into account and to adapt the retention period to the actual informational needs." In this regard, while favorably noting the corrective measure already undertaken by Inps, it is believed that the submissions presented are not adequate to overcome the contestation regarding the violation by Inps of the obligation to provide accurate and complete information pursuant to Article 14 of the Regulation with specific reference to the statistical work IPS-00081.

4.4. On the obligation to conduct an impact assessment

With reference to the contestation of the violation by the Institute of the obligation to conduct an impact assessment pursuant to Article 35 of the Regulation, concerning the statistical works included in the PSN and particularly in relation to those IPS-00081 and IPS-00061, the Institute represented that "the General Data Protection Regulation requires that data controllers implement adequate measures to ensure and be able to demonstrate compliance with this regulation, taking into account, among other things, the 'risks with varying probabilities and severity for the rights and freedoms of natural persons' (Article 24, paragraph 1). The obligation for data controllers to carry out a data protection impact

assessment should be understood in the context of the general obligation to adequately manage the risks presented by the processing of personal data." The Institute also referred to the aforementioned WP29 guidelines in the part where they indicate that...

"when the types of processing have been verified by a supervisory authority before May 2018 under specific conditions that have not changed (see III.C)" highlighted that it would not be "correct to note by the Department that the Institute would have violated the obligation of impact assessment" despite what is indicated in the PSN (where the Institute in the section "Organizational and technical measures for the implementation of personal data protection principles, declares to carry out the VIPs in relation to high-risk processing) as "It does not appear, in fact, that in previous PSNs the Institute declared to have in any way proceeded with an impact assessment before proceeding with the processing related to statistical work. Furthermore, in previous PSNs, the statistical work referred to in inspection IPS-00081 (previously named IPS-00062) had been specifically approved with all its characteristics and methods of processing personal data" and that "A first indication regarding the need for specific impact assessments came only from the decision of the Guarantor no. 315 of September 16, 2021. And indeed, at the time of the inspection, the preparatory investigative activities and assessments regarding all the issues outlined in this note were ongoing."

In this regard, it is noted that in a regulation centered on the precautionary principle and the risk-based approach, such as that of the Regulation, the discretion regarding the obligation to carry out or not carry out the impact assessment is entirely unfounded. This is also considering how well detailed, in Article 35 of the Regulation, the cases for which such compliance is deemed necessary are, and then further specified in the cited guidelines.

That said, from another perspective, it is worth clarifying that, as repeatedly indicated by the Guarantor, the opinion that the Authority renders on the PSN pursuant to Article 58, paragraph 3, letter b) and paragraph 2 letter f) of the Regulation, Article 6-bis of Legislative Decree 322 of 1989, and Article 4-bis of the Deontological Rules, concerns the consultative tasks and functions of the Authority on regulatory acts that affect data protection. Therefore, the possibility for the Guarantor to carry out specific investigative deepening on the processing of personal data carried out for the realization of the statistical works indicated therein remains unaffected, also in order, if necessary, to verify their compliance with what was represented by the data controller in the aforementioned act.

In other words, the fact that the Guarantor has given a favorable opinion on the PSNs in which INPS has included the statistical works of which it is the owner implies that the Institute, like other Sistan entities, enjoys an appropriate legal basis for the processing of personal data necessary for such purposes, but does not exempt it from the obligation to carry out the further compliance measures provided for by the Regulation. The obligations to carry out the impact assessment pursuant to Article 35 of the Regulation and to apply appropriate data minimization measures, as provided for by the Regulation, evidently precede and are independent of the warning that the Authority had already made in the decision of September 16, 2021 (cited), which INPS has demonstrated it did not duly consider, given that at present the process of drafting the impact assessments does not appear to be completed.

That said, it is believed that the defensive memoranda presented do not allow for overcoming the dispute regarding the violation by the Institute of the obligation to carry out the impact assessment pursuant to Article 35 of the Regulation in relation to the statistical works included in the PSN and in particular in relation to those IPS-00081 and IPS-00061 subject to the inspection checks of the Office.

4.5 On the operation of data anonymization and the principle of accountability. The dispute regarding the violation of the accountability principle under Article 5, paragraph 2 of the Regulation, with reference to the data anonymization techniques preparatory to the dissemination of statistical results, carried out through an external company appointed as data processor, pursuant to Article 28 of the Regulation, particularly concerned the circumstance that the Institute was unable to demonstrate, prove, and substantiate that it had implemented measures effectively suitable to prevent the risk of re-identification of the data subjects during dissemination.

In this regard, the Institute, while excluding that based on the applied techniques the statistical result

could reasonably allow the identification of statistical units, considering the type of survey and the nature of the associated variables, referring in particular to the surveys, IPS-00081 and IPS-00061, stated that "for the sole purpose of greater caution, the CGSA on January 22 sent, via institutional communication to the DCTII, a document on data processing for the protection of confidentiality in the release of statistical information in which it requests the application of a minimum frequency threshold of 3 (a rule accepted by many national statistical institutes, including Article 4 of the Deontological Rules for processing for statistical or scientific research purposes carried out within the National Statistical System published pursuant to Article 20, paragraph 4, of Legislative Decree August 10, 2018, no. 101 - December 19, 2018) in the visualization of the navigable statistical tables of the online Observatories."

The Institute also added that "in light of the large amount of data processed over the years by the actuarial statistical coordination both in clear and..."

with anonymization/pseudonymization techniques

no violation of personal data has been recorded

consisting in the identification/

identifiability of the data subjects, nor loss of

confidentiality of the data themselves."

In this regard, it is noted that, after the

anonymization/aggregation operation of the statistical results subject to dissemination, the verification of the

risk of re-identification of the data subjects requires

that the data controller identifies concrete measures,

feasible in an automated manner and exempt from

ictu oculi assessments conducted only on an

occasional and non-systematic basis, to avoid the

publication of so-called "hypercubes," i.e.,

combinations of ranges of variables, containing a

number of statistical units less than 3 units.

The ex post control carried out by the Institute in

manual and sample mode means that some of the

disseminations carried out are not subject to any

verification. This practice constitutes an even more

significant criticality considering that the

effectiveness of the K-anonymity technique (which

must be evaluated in concrete terms) must be weighed

based on the characteristics of each survey related to

the degree of "diversity" of the statistical units

included in each equivalence class (for example, it

may well occur that equivalence classes with more

than three units are characterized by similar, if not

identical, values of attributes such as diseases,

income levels, etc. – the so-called quasi-identifiers –)

(cf. provision of March 2, 2023, web doc 9875254 and

of July 18, 2023, web doc 9920977), potentially

nullifying the applied generalization. This is also

considering that the Institute boasts a very

significant statistical production with a significant

variability of the samples in which particular

categories of data are also recorded, such as those

related to health or the disability conditions of the

data subjects. In this regard, it is sufficient to

consider, by way of example, that, only in the PSN

2023-2025, there are as many as 27 statistical works owned by INPS without taking into account those in which the Institute participates in another capacity or those carried out outside the PSN.

It is also emphasized that the anonymization/ aggregation of the data processed for statistical purposes in order to provide the result of the work performed constitutes a central operation in the examined sector as it is not only necessary to prevent the dissemination of personal data in the absence of an appropriate legal basis but also to ensure compliance with statistical confidentiality (Articles 2-sexies and 2-septies, paragraph 8 of the Code and Article 9 of Legislative Decree 322 of 1989).

For all the above reasons, while favorably noting the measures recently implemented that the data controller has described in the documentation acquired in the proceedings, it is believed that the defensive memoranda presented are not suitable to overcome the contestation of the violation of the accountability principle by the Institute in relation to the operation of anonymization/aggregation of the data processed for statistical purposes, which is preparatory to the dissemination of statistical results, pursuant to Article 5, paragraph 2 of the Regulation.

5. Conclusions

In light of the assessments mentioned above, considering the statements made pursuant to Article 168 of the Code during the investigation and the elements provided by the data controller in the defensive memoranda, although deserving of consideration, do not allow, as illustrated and reasoned above, to overcome the majority of the observations notified by the Office with the act of initiation of the proceedings, nor do any of the cases provided for by Article 11 of the Regulation of the Guarantor No. 1/2019 apply.

For these reasons, the illegality of the processing of personal data carried out by the National Social Security Institute is noted as it violates Articles 5, paragraph 1, letter c), and paragraph 2 and Articles 25 and 35 of the Regulation, as well as with specific reference to the statistical work IPS-00081 of the obligation to provide accurate and complete information pursuant to Article 14 of the Regulation. The violation of the aforementioned provisions makes applicable the administrative sanction provided for by Article 83, paragraphs 4 and 5 of the Regulation, pursuant to Articles 58, paragraph 2, letter i), and 83, paragraph 3, of the same Regulation and Article 166, paragraph 2 of the

Code.

6. Corrective Measures

Article 58, paragraph 2 of the Regulation provides the Guarantor with a series of corrective powers, of a prescriptive and sanctioning nature, to be exercised in the event that an unlawful processing of personal data is established, including the power to "order the data controller or the data processor to bring the processing into compliance with the provisions of this regulation, if necessary, in a certain manner and within a certain period" (Article 58, paragraph 2, letter d) of the Regulation).

In light of the assessments mentioned above, it is deemed necessary to order the Institute, pursuant to the aforementioned Article 58, paragraph 2, letter d) of the Regulation, to take action within 180 days from the notification of this provision to:

- identify pseudonymization techniques for the data and, in particular, for the tax code, which, while maintaining the uniqueness of the records, allow, by default setting, to effectively apply the principle of data minimization in the context of the processing of personal data necessary for the INPS statistical office to carry out its institutional functions;
- initiate and complete the impact assessments related to the statistical works included in the PSN referred to in Article 35 of the Regulation and specifically those related to works IPS-00081 and IPS-00061;
- identify specific measures for the assessment of the risk of re-identification of the data subjects during the dissemination of statistical results that can be implemented in an automated manner and that provide guarantees of effectiveness in the implementation of the k-anonymity technique with the application of the rule of 3, also in order to provide specific indications in this regard to the external company responsible for data anonymization on behalf of the Institute, in view of the dissemination of statistical results.

7. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (arts. 58, par. 2, lett. i and 83 of the Regulation; art. 166, comma 7, of the Code). The violation of art. 5, par. 1, lett. c), and par. 2 and of arts. 14, 25 and 35 of the Regulation committed by the Institute is subject to the application of the administrative pecuniary sanction, pursuant to art. 83, par. 4, lett. a) and 5, lett. a) and b) of the Regulation.

The Guarantor, pursuant to arts. 58, par. 2, lett. i) and 83 of the Regulation, as well as art. 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to article 83, in addition to the [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case" and, in this context, "the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to article 166, comma 7, of the Code" (art. 16, comma 1, of the Guarantor's Regulation no. 1/2019).

The aforementioned administrative pecuniary sanction imposed depending on the circumstances of each individual case must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, indicated in art. 83, par. 1, of the Regulation, in light of the elements provided for in art. 83, par. 2 of the Regulation.

In light of the above and in particular the high number of affected subjects, the special categories of

data that may be the subject of the violation, the purposes of the processing, which do not fall within the main activities of the data controller, and the unintentional nature of the violation, it is believed that the level of severity of the violation committed by the Institute is medium (cf. European Data Protection Board, "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" of May 23, 2023, point 60).

That said, with reference to the elements listed in art. 83, par. 2 of the Regulation for the purpose of applying the administrative pecuniary sanction and its quantification, considering that the sanction must be "effective, proportionate, and dissuasive in each individual case" (art. 83, par. 1 of the Regulation), it is represented that, in the case at hand, the following circumstances have been taken into account, and, in particular, that:

- the processing carried out concerned, in particular, the performance of the institutional functions of Inps related to the production of official statistics through the reprocessing of information already held by the Institute for administrative purposes;
- there are no previous relevant violations, therefore concerning the processing carried out for statistical purposes, committed by the data controller nor have any measures been previously ordered, in relation to the aforementioned processing, pursuant to art. 58 of the Regulation (art. 83, par. 2, lett. e) of the Regulation);
- the Institute has shown cooperation during the inspection assessment and this proceeding;
- the Institute has stated that it has already implemented some corrective measures regarding the processing of personal data carried out (art. 83, par. 2, lett. c) of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the pecuniary sanction provided for by art. 83, par. 4 and 5, of the Regulation, in the amount of € 40,000.00 (forty thousand/00) for the violation of art. 5, par. 1, lett. c), and par. 2 and of arts. 14, 25 and 35 of the Regulation as an administrative pecuniary sanction deemed, pursuant to art. 83, par. 1 and 3, of the Regulation, effective, proportionate, and dissuasive.

In this context, it is also deemed appropriate to proceed with the publication, on the Guarantor's website, of this section containing the injunction order pursuant to art. 166, comma 7, of the Code and art. 16, comma 1, of the Guarantor's Regulation no. 1/2019.

This is in consideration of the seriousness of the conduct that led to the aforementioned violations of the regulation on the protection of personal data, the high number of affected subjects involved, and the special categories of data processed.

ALL OF THE ABOVE HAVING BEEN STATED, THE GUARANTOR

declares the unlawfulness of the processing of personal data carried out by the National Institute of Social Security with registered office at Via Ciro il Grande, 21 cap 00144 Rome VAT number 02121151001, for the violation of art. 5, par. 1, lett. c) and par. 2 and of arts. 14, 25 and 35 of the Regulation as stated in the motivation.

ORDERS

pursuant to arts. 58, par. 2, lett. i) and 83 of the Regulation, as well as art. 166 of the Code, the Institute to pay the sum of € 40,000.00.

(€40,000.00) as an administrative monetary sanction for the violations indicated in this provision. It is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to resolve the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction.

ORDERS

the Institute:

1. to pay the sum of €40,000.00 (€40,000.00) -in case of failure to resolve the dispute pursuant to Article 166, paragraph 8, of the Code-, according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent executive acts in accordance with Article 27 of Law No. 689/1981;
2. pursuant to Article 58, paragraph 2, letter d), of the Regulation, to conform the treatments to the provisions of the Regulation, adopting within 180 days from the notification of this provision, the corrective measures indicated in paragraph 6 of this provision. Non-compliance with an order issued

pursuant to Article 58, paragraph 2, of the Regulation is punishable by the administrative sanction referred to in Article 83, paragraph 6, of the Regulation;

3. pursuant to Article 58, paragraph 1, letter a), of the Regulation and Article 157 of the Code, to communicate what initiatives have been undertaken in order to implement what is prescribed in paragraph 6 and to provide feedback, adequately documented, within 20 days from the expiration of the deadline referred to in point 2. Failure to respond to a request made pursuant to Article 157 of the Code is punishable by the administrative sanction, pursuant to the combined provisions of Articles 83, paragraph 5, of the Regulation and 166 of the Code.

DECIDES

a) pursuant to Article 166, paragraph 7 of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor No. 1/2019, the publication of the injunction order on the Guarantor's website;

b) pursuant to Article 154-bis, paragraph 3 of the Code and Article 37 of the Regulation of the Guarantor No. 1/2019, the publication of this provision on the website of the Authority;

c) pursuant to Article 17 of the Regulation of the Guarantor No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, November 13, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei